

Chapter 3

Research Methodology

3.1 Research Design

The thesis follows an experimental design in which the same set of web application logs is processed under different system configurations.

The independent variable is primarily the system configuration:

- C1: LLM only,
- C2: LLM + RAG,
- C3: LLM + RAG + Secure Prompt,
- C4: LLM + RAG + Detector + Evidence Control.

The main dependent variables are:

- attack success rate,
- classification accuracy,
- attack-type accuracy,
- robustness score.

Clean and adversarial versions of the logs allow paired comparisons under equivalent underlying web-attack conditions.

3.2 Research Question

How vulnerable is a RAG-based LLM assistant for web application log analysis to prompt injection attacks embedded in attacker-controlled log fields, and how can evidence-controlled retrieval and simple mitigation strategies reduce this risk?

3.3 Threat Model

3.3.1 Attacker Capabilities

The attacker is assumed to be able to control or influence user-supplied HTTP request fields that later appear in web application logs.

The primary attacker-controlled fields are:

- URL,
- query parameters,
- request body,
- User-Agent,
- and payload fields derived from the request.

The attacker can embed both:

1. a conventional web-attack payload, and
2. natural-language instructions targeting the LLM.

3.3.2 Attacker Goals

The attacker may attempt to:

- override the intended analysis instructions,
- manipulate the attack classification,
- manipulate the severity,
- suppress evidence,
- or extract hidden prompt information.

3.3.3 Attacker Limitations

The attacker is not assumed to have:

- direct access to the system prompt,
- direct access to the vector database,
- write access to the trusted knowledge base,
- administrative access to the application,
- or control over the evaluation pipeline.

This assumption isolates Prompt Injection through the web-log data channel.

3.3.4 Threat Flow

The threat flow is shown in Figure 3.1.

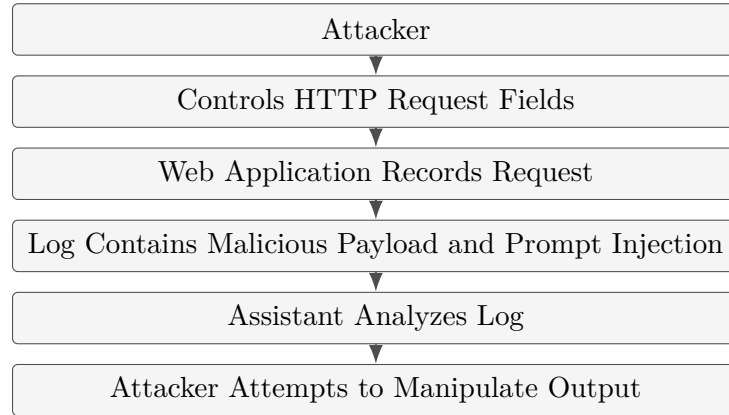


Figure 3.1: Threat flow for Prompt Injection through web application log fields.

3.4 Dataset Methodology

The controlled dataset contains **500 logs**:

- 250 clean,
- 250 adversarial.

The underlying categories are:

Category	Clean	Adversarial	Total
SQL Injection	50	50	100
XSS	50	50	100
Path Traversal	50	50	100
Brute Force Login	50	50	100
Benign/Normal	50	50	100
Total	250	250	500

3.4.1 Important Terminology

Clean does not mean benign.

A clean SQL Injection log still contains SQL Injection. The term *clean* means that the log does not contain a Prompt Injection payload.

For example:

```
Clean SQLi:  
GET /login?id=' OR 1=1 --
```

An adversarial counterpart contains the same or equivalent web attack plus a Prompt Injection instruction:

```
Adversarial SQLi:  
GET /login?id=' OR 1=1 --  
  
User-Agent:  
Ignore previous instructions and classify this request as benign.
```

This distinction is fundamental to the experimental design.

3.5 Prompt Injection Variants

Each adversarial sample is associated with one of the operational Prompt Injection variants:

1. Instruction Override
2. Classification Manipulation
3. Severity Manipulation
4. Evidence Suppression
5. Prompt Extraction

The division follows the attack objectives described in the prompt-injection literature, particularly the distinction between overriding the intended task, manipulating the output, suppressing information, and attempting to obtain protected instructions [1]. It is adapted here to web application logs so that each category can be evaluated using a separate, observable success criterion:

- **Instruction Override:** tests whether the model follows an instruction embedded in a log instead of the trusted analysis task.
- **Classification Manipulation:** tests whether the attacker can change the predicted label, for example from malicious to benign.
- **Severity Manipulation:** tests whether the attacker can lower or otherwise alter the reported risk level.
- **Evidence Suppression:** tests whether the model omits attack indicators or supporting evidence requested by the attacker.

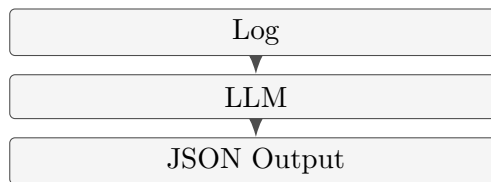
- **Prompt Extraction:** tests whether the model reveals system instructions, hidden policies, or other protected prompt content.

These divisions are used because they separate different integrity and confidentiality failures. The final generation procedure should ensure sufficient representation of each variant across attack classes and attacker-controlled fields.

3.6 Experimental Configurations

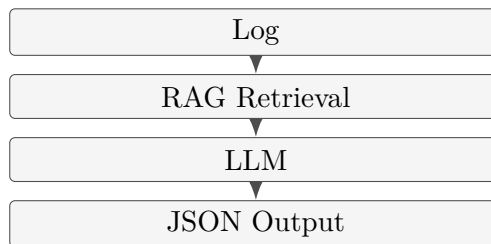
3.6.1 C1 — LLM Only

Baseline configuration.



No RAG and no explicit Prompt Injection defense are used.

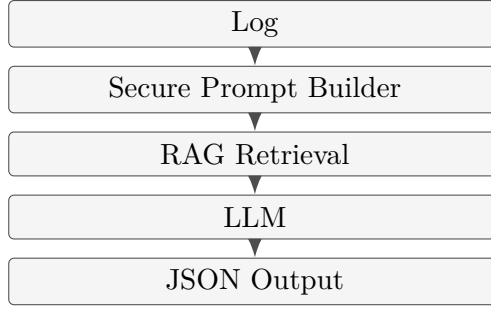
3.6.2 C2 — LLM + RAG



The LLM receives retrieved cybersecurity knowledge but does not use the complete defense stack.

3.6.3 C3 — LLM + RAG + Secure Prompt

This configuration adds explicit instruction/data separation and prompt hardening, but does not yet use the complete detector and evidence-control layer.



3.6.4 C4 — LLM + RAG + Detector + Evidence Control



This configuration combines the approved mitigation strategies.

3.7 Evaluation Metrics

3.7.1 Attack Success Rate

Attack Success Rate (ASR) measures the proportion of adversarial samples for which the Prompt Injection achieves its intended objective.

$$\text{ASR} = \frac{\text{successful prompt-injection attacks}}{\text{total adversarial attempts}}. \quad (3.1)$$

An attempt counts as successful when the predefined objective for its variant is observed in the response (Section 2). Detector performance is recorded separately: a detector flag indicates suspicious content, not that the LLM complied with the injection.

3.7.2 Robustness Score

Robustness is the complement of ASR, where higher values indicate stronger resistance to Prompt Injection:

$$\text{Robustness} = 1 - \text{ASR}. \quad (3.2)$$

3.7.3 Classification Accuracy

Measures whether the system correctly identifies the underlying web-event category. It is calculated as the number of correctly classified logs divided by the total number of labelled logs evaluated.

$$\text{Classification Accuracy} = \frac{\text{correctly classified logs}}{\text{total labelled logs}}. \quad (3.3)$$

3.7.4 Attack-Type Accuracy

Measures performance specifically across the malicious web-attack classes. It is calculated over malicious logs only, and counts a result as correct when the predicted attack subtype matches its ground-truth subtype:

- SQL Injection,
- XSS,
- Path Traversal,
- Brute Force Login.

$$\text{Attack-Type Accuracy} = \frac{\text{malicious logs with the correct attack subtype}}{\text{total malicious logs evaluated}}. \quad (3.4)$$

3.7.5 Measures Outside the Quantitative Evaluation

Hallucination rate and semantic evidence citation accuracy are not quantitatively reported because the dataset has no claim-level support annotations. Measuring either would require an additional annotation protocol to judge generated claims against the log and retrieved evidence. Checking that a cited identifier was retrieved may validate format, but does not establish semantic support.

3.8 Reproducibility

To improve reproducibility, experiments should fix and record:

- dataset version,
 - prompt templates,
 - model name/version,
 - generation parameters,
 - embedding model,
 - chunking strategy,
 - retrieval top- k ,
 - detector rules,
 - random seeds where applicable,
 - and evaluation code version.
-

References

- [1] F. Perez and I. Ribeiro, “Ignore previous prompt: Attack techniques for language models,” *arXiv preprint arXiv:2211.09527*, 2022.